

# ISO/IEC 27001:2022

## Sistema de Gestión de Seguridad de la Información

*Guía Completa para Proyecto Fin de Carrera*

---

### **Contenidos:**

1. Introducción y estructura de la norma
2. Gestión de Riesgos
3. Control de Accesos
4. Seguridad de la Información
5. Copias de Seguridad
6. Continuidad de Negocio
7. Proceso de Certificación
8. Anexo A — Controles de Referencia

# 1. Introducción a ISO/IEC 27001:2022

## 1.1 ¿Qué es la ISO 27001?

La norma ISO/IEC 27001 es el estándar internacional para la gestión de la seguridad de la información. Publicada por la Organización Internacional de Normalización (ISO) y la Comisión Electrotécnica Internacional (IEC), define los requisitos para establecer, implementar, mantener y mejorar continuamente un Sistema de Gestión de Seguridad de la Información (SGSI).

La versión vigente es la ISO/IEC 27001:2022, que sustituyó a la versión de 2013 e introdujo cambios significativos en la estructura del Anexo A, reduciendo los controles de 114 a 93 y reorganizándolos en 4 categorías temáticas.

## 1.2 Objetivos de la norma

- Proteger la confidencialidad, integridad y disponibilidad de la información.
- Proporcionar un marco sistemático para gestionar los riesgos de seguridad.
- Demostrar a clientes, socios y organismos reguladores el compromiso con la seguridad.
- Cumplir con requisitos legales y reglamentarios (RGPD, ENS, NIS2, etc.).
- Mejorar la confianza y reputación de la organización.

## 1.3 Estructura de la norma (cláusulas 4-10)

La ISO 27001:2022 sigue la estructura de alto nivel (HLS) común a todos los estándares de gestión ISO, lo que facilita su integración con otras normas como ISO 9001 o ISO 22301.

| Cláusula | Título                      | Descripción                                                                    |
|----------|-----------------------------|--------------------------------------------------------------------------------|
| 4        | Contexto de la organización | Identificar partes interesadas, alcance del SGSI y factores internos/externos. |
| 5        | Liderazgo                   | Compromiso de la dirección, política de seguridad y asignación de roles.       |
| 6        | Planificación               | Gestión de riesgos, objetivos de seguridad y planes de tratamiento.            |
| 7        | Soporte                     | Recursos, competencias, comunicación y documentación.                          |
| 8        | Operación                   | Implementación y control de procesos, evaluación de riesgos.                   |
| 9        | Evaluación del desempeño    | Seguimiento, medición, auditoría interna y revisión por la dirección.          |
| 10       | Mejora                      | No conformidades, acciones correctivas y mejora continua (PDCA).               |

## 1.4 El ciclo PDCA en el SGSI

La norma se basa en el ciclo de mejora continua PDCA (Plan-Do-Check-Act):

- **PLANIFICAR (Plan):** Definir la política, los objetivos y los procesos del SGSI. Realizar la evaluación de riesgos y elaborar el plan de tratamiento.
- **HACER (Do):** Implementar y operar el SGSI, aplicar los controles seleccionados.
- **VERIFICAR (Check):** Monitorizar, medir y revisar el SGSI frente a la política y los objetivos.
- **ACTUAR (Act):** Tomar acciones correctivas y preventivas. Implementar mejoras.

## 2. Gestión de Riesgos (Cláusulas 6 y 8)

### 2.1 Concepto y marco de referencia

La gestión de riesgos es el núcleo del SGSI. La ISO 27001 exige que las organizaciones identifiquen, analicen, evalúen y traten los riesgos de seguridad de la información de manera sistemática y documentada. Se complementa con la norma ISO/IEC 27005, específica para la gestión de riesgos de seguridad de la información.

Un riesgo se define como la combinación de la probabilidad de que ocurra una amenaza y el impacto que tendría sobre los activos de información de la organización.

### 2.2 Proceso de gestión de riesgos

#### 2.2.1 Identificación de activos

El primer paso es inventariar todos los activos de información que deben protegerse. Existen varias categorías:

- Activos de información: bases de datos, contratos, procedimientos, documentación técnica.
- Activos de software: aplicaciones, sistemas operativos, herramientas de desarrollo.
- Activos físicos: servidores, equipos de red, estaciones de trabajo, dispositivos móviles.
- Servicios: servicios en la nube, suministro eléctrico, comunicaciones.
- Personas: empleados, contratistas, proveedores con acceso a información sensible.

#### 2.2.2 Identificación de amenazas y vulnerabilidades

Para cada activo se identifican las amenazas (causas potenciales de incidentes) y las vulnerabilidades (debilidades que pueden ser explotadas).

| Tipo de amenaza              | Ejemplos                                                                          |
|------------------------------|-----------------------------------------------------------------------------------|
| Amenazas humanas internas    | Acceso no autorizado por empleados, errores humanos, uso indebido de privilegios. |
| Amenazas humanas externas    | Hackers, ataques de phishing, ransomware, espionaje industrial.                   |
| Amenazas técnicas            | Fallos de hardware, bugs de software, vulnerabilidades de red.                    |
| Amenazas físicas/ambientales | Incendios, inundaciones, cortes de suministro eléctrico.                          |
| Amenazas organizativas       | Falta de procedimientos, personal sin formación, proveedores inseguros.           |

#### 2.2.3 Análisis y evaluación del riesgo

Cada riesgo se evalúa en función de dos dimensiones:

- Probabilidad (Likelihood): ¿Con qué frecuencia podría materializarse la amenaza? Se suele valorar en una escala de 1 a 5 (muy baja a muy alta).

- Impacto (Impact): ¿Cuál sería la consecuencia para la organización si el riesgo se materializara? También se valora de 1 a 5.

El nivel de riesgo se calcula como:  $\text{Riesgo} = \text{Probabilidad} \times \text{Impacto}$

| Nivel de Riesgo | Puntuación | Acción requerida                                  |
|-----------------|------------|---------------------------------------------------|
| Crítico         | 15-25      | Tratamiento inmediato. Plan de acción urgente.    |
| Alto            | 10-14      | Tratamiento prioritario. Controles inmediatos.    |
| Medio           | 5-9        | Tratamiento planificado. Controles a medio plazo. |
| Bajo            | 1-4        | Aceptable con monitorización. Controles básicos.  |

## 2.2.4 Tratamiento del riesgo

Una vez evaluado, cada riesgo debe tratarse mediante una de las siguientes opciones:

- Mitigar (Reducir): Implementar controles para reducir la probabilidad o el impacto. Es la opción más habitual.
- Aceptar: Asumir el riesgo cuando el coste del control supera el impacto potencial o el nivel es bajo.
- Transferir: Contratar un seguro o externalizar la actividad para trasladar el riesgo a un tercero.
- Evitar (Eliminar): Decidir no realizar la actividad que genera el riesgo.

## 2.2.5 Plan de Tratamiento de Riesgos (PTR)

El Plan de Tratamiento de Riesgos (PTR) documenta para cada riesgo: el control seleccionado del Anexo A, el responsable de su implementación, el plazo estimado, los recursos necesarios y el riesgo residual esperado. Este documento es uno de los artefactos más importantes para la auditoría de certificación.

## 2.3 Declaración de Aplicabilidad (SoA)

La Declaración de Aplicabilidad (Statement of Applicability, SoA) es un documento obligatorio que lista todos los controles del Anexo A de la norma e indica para cada uno si es aplicable o no a la organización, y la justificación de esa decisión. Para los controles aplicables, indica si ya están implementados o en proceso.

## 3. Control de Accesos

### 3.1 Definición y propósito

El control de accesos es el conjunto de mecanismos, políticas y procedimientos que garantizan que únicamente las personas, sistemas o procesos autorizados puedan acceder a los activos de información, y solo en la medida necesaria para el ejercicio de sus funciones. Está regulado principalmente por el Control 5.15 al 5.18 del Anexo A de la ISO 27001:2022.

### 3.2 Principios fundamentales

- **Mínimo privilegio (Least Privilege):** Cada usuario o sistema recibe exclusivamente los permisos indispensables para realizar sus tareas. Se reduce así el radio de acción en caso de compromiso.
- **Necesidad de conocer (Need to Know):** El acceso a información clasificada o sensible se concede solo si la persona necesita conocer esa información para su trabajo.
- **Separación de funciones (Segregation of Duties):** Las tareas críticas se dividen entre varias personas para evitar el fraude o el error. Ejemplo: quien aprueba pagos no puede también ejecutarlos.
- **Defensa en profundidad:** Se implementan múltiples capas de control de acceso para que el fallo de una no comprometa todo el sistema.

### 3.3 Ciclo de vida de la gestión de identidades y accesos (IAM)

#### 3.3.1 Altas (provisioning)

Cuando un nuevo usuario se incorpora, se crea su cuenta siguiendo un proceso formal: solicitud aprobada por el responsable del área, creación de credenciales según la política de contraseñas, asignación de roles predefinidos (RBAC) y comunicación segura de las credenciales.

#### 3.3.2 Modificaciones

Cuando un usuario cambia de puesto o responsabilidades, sus permisos deben revisarse y actualizarse de inmediato. Se aplica el principio de revisión periódica de accesos (Access Review), al menos anualmente o tras cambios organizativos.

#### 3.3.3 Bajas (deprovisioning)

En el momento en que un empleado abandona la organización, se deben revocar todos sus accesos el mismo día de la baja, recuperar credenciales y dispositivos corporativos y eliminar o deshabilitar todas las cuentas.

### 3.4 Métodos de autenticación

| Factor         | Tipo     | Ejemplos                                           | Nivel de seguridad |
|----------------|----------|----------------------------------------------------|--------------------|
| Algo que sabes | Factor 1 | Contraseñas, PINs, respuestas a preguntas secretas | Bajo (si débil)    |

|                    |                      |                                                   |            |
|--------------------|----------------------|---------------------------------------------------|------------|
| Algo que tienes    | Factor 2             | Token OTP, tarjeta inteligente, app autenticadora | Medio-Alto |
| Algo que eres      | Factor 3 (biometría) | Huella dactilar, reconocimiento facial, iris      | Alto       |
| MFA (Multi-Factor) | Combinación          | Contraseña + OTP / Tarjeta + PIN + biometría      | Muy alto   |

### 3.5 Modelos de control de acceso

- **DAC (Discretionary Access Control):** El propietario del recurso decide quién accede. Flexible pero arriesgado si los propietarios no son cuidadosos.
- **MAC (Mandatory Access Control):** El sistema impone reglas basadas en etiquetas de clasificación (secreto, confidencial, público). Muy usado en entornos militares/gubernamentales.
- **RBAC (Role-Based Access Control):** Los permisos se asignan a roles, no a individuos. Es el modelo más extendido en entornos empresariales. Facilita la gestión y la auditoría.
- **ABAC (Attribute-Based Access Control):** El acceso se determina por atributos del usuario, del recurso y del contexto (hora, ubicación, dispositivo). Muy flexible y granular.

### 3.6 Control de acceso físico

El control de acceso no se limita a los sistemas informáticos. La ISO 27001 también exige proteger el acceso físico a las instalaciones donde se procesa o almacena información:

- **Perímetros de seguridad física:** áreas delimitadas con control de entrada (tarjetas, cerraduras, guardias).
- **Zonas de acceso restringido:** centros de datos, salas de servidores, archivos clasificados.
- **Registro de visitas:** control y registro de todas las personas que acceden a áreas sensibles.
- **CCTV y alarmas:** vigilancia continua de instalaciones críticas.

### 3.7 Registro y auditoría de accesos

Todo acceso a sistemas y recursos debe registrarse en logs de auditoría que incluyan: identificador del usuario, fecha y hora del acceso, sistema o recurso accedido, acción realizada y resultado (éxito/fallo). Estos registros deben protegerse contra modificación y conservarse según la política de retención definida.

## 4. Seguridad de la Información

### 4.1 La tríada CIA

El concepto fundamental de la seguridad de la información se articula en torno a tres pilares conocidos como la tríada CIA:

| Pilar            | Definición                                      | Ejemplo de amenaza                          | Control típico                                         |
|------------------|-------------------------------------------------|---------------------------------------------|--------------------------------------------------------|
| Confidencialidad | Solo los autorizados acceden a la información.  | Filtración de datos, espionaje.             | Cifrado, control de acceso, clasificación.             |
| Integridad       | La información no se altera sin autorización.   | Ransomware, inyección SQL, errores humanos. | Hashes, firmas digitales, control de versiones.        |
| Disponibilidad   | La información es accesible cuando se necesita. | DDoS, fallos hardware, desastres naturales. | Redundancia, copias de seguridad, alta disponibilidad. |

### 4.2 Clasificación de la información

La ISO 27001 exige que las organizaciones clasifiquen su información según su sensibilidad e importancia. Esta clasificación determina qué controles de protección se aplican. Un esquema típico de clasificación es:

- Pública: Información que puede divulgarse libremente sin consecuencias. Ejemplo: comunicados de prensa, catálogos de productos.
- Interna: Información de uso interno, no clasificada como confidencial pero no destinada al público. Ejemplo: procedimientos internos, organigramas.
- Confidencial: Información sensible cuya divulgación no autorizada causaría daños a la organización. Ejemplo: estrategias de negocio, datos de clientes.
- Secreta/Restringida: Información altamente sensible, acceso muy limitado. Ejemplo: secretos comerciales, datos de seguridad nacional.

### 4.3 Seguridad en el ciclo de vida de la información

La información debe protegerse durante todo su ciclo de vida:

- Creación: Aplicar controles desde el origen. Clasificar al crear.
- Almacenamiento: Cifrado en reposo, control de acceso, ubicaciones seguras.
- Transmisión: Cifrado en tránsito (TLS/SSL, VPN), protocolos seguros.
- Uso: Controles en el puesto de trabajo, DLP (Data Loss Prevention), restricción de exportación.
- Archivo: Políticas de retención, almacenamiento seguro a largo plazo.
- Destrucción: Borrado seguro (NIST 800-88), destrucción física certificada.

### 4.4 Cifrado (Control 8.24 del Anexo A)



El cifrado es uno de los controles más importantes de la norma. Se aplica tanto a datos en reposo como en tránsito:

- Cifrado en reposo: AES-256 para discos y bases de datos. Cifrado de dispositivos móviles (BitLocker, FileVault).
- Cifrado en tránsito: TLS 1.2/1.3 para comunicaciones web y API. SSH para acceso remoto. S/MIME o PGP para correo electrónico.
- Gestión de claves: Las claves deben gestionarse con procedimientos documentados: generación, distribución, almacenamiento, rotación y revocación.

## 4.5 Seguridad en el puesto de trabajo

- Política de escritorio limpio (Clean Desk Policy): Ningún documento sensible visible cuando el puesto no está en uso.
- Política de pantalla limpia (Clear Screen Policy): Bloqueo automático de pantalla tras inactividad.
- Control de dispositivos extraíbles: Restricción o prohibición de uso de USB no autorizados.
- Software antimalware: Actualizado y con análisis en tiempo real en todos los endpoints.
- Gestión de parches: Procedimiento formal para aplicar actualizaciones de seguridad en los plazos definidos.

## 5. Copias de Seguridad

### 5.1 Marco normativo

El Control 8.13 del Anexo A de la ISO 27001:2022 establece que la organización debe implementar y gestionar una política de copias de seguridad para proteger los datos frente a pérdida, corrupción o destrucción accidental o maliciosa.

### 5.2 Tipos de copias de seguridad

| Tipo            | Descripción                                                            | Ventajas                                                  | Inconvenientes                                      |
|-----------------|------------------------------------------------------------------------|-----------------------------------------------------------|-----------------------------------------------------|
| Completa (Full) | Copia de todos los datos.                                              | Restauración simple y rápida.                             | Mayor tiempo y espacio de almacenamiento.           |
| Incremental     | Solo copia los cambios desde la última copia (completa o incremental). | Rápida. Menor espacio.                                    | Restauración más compleja (requiere varias copias). |
| Diferencial     | Copia los cambios desde la última copia completa.                      | Equilibrio entre velocidad y simplicidad de restauración. | Crece en tamaño a lo largo del tiempo.              |
| Espejo (Mirror) | Réplica exacta y en tiempo real.                                       | Recuperación instantánea.                                 | No protege contra borrado accidental o ransomware.  |

### 5.3 Regla 3-2-1

La regla 3-2-1 es la práctica recomendada para garantizar la resiliencia de las copias de seguridad:

- 3 copias de los datos (la original más dos copias de seguridad).
- 2 medios de almacenamiento diferentes (por ejemplo, disco local y cinta/nube).
- 1 copia offsite o en la nube, geográficamente separada de las demás.

En entornos críticos se recomienda ampliar a la regla 3-2-1-1-0, que añade 1 copia offline (air-gapped) y 0 errores verificados en las restauraciones.

### 5.4 Política de copias de seguridad

La política debe definir al menos los siguientes aspectos:

- Alcance: Qué datos y sistemas se incluyen en las copias.
- Frecuencia: Diaria, semanal, mensual según criticidad del activo.
- Retención: Cuánto tiempo se conservan las copias (30 días, 1 año, 7 años según requisitos legales).
- Cifrado: Las copias deben estar cifradas, especialmente las offsite.
- Pruebas de restauración: Verificación periódica de que las copias pueden restaurarse correctamente. Al menos una vez al año.
- Responsables: Quién ejecuta, monitoriza y verifica las copias.

## 5.5 Copias de seguridad en la nube

El uso de servicios cloud para backups (AWS S3, Azure Backup, Google Cloud Storage) requiere consideraciones adicionales:

- Verificar el cumplimiento del proveedor con la ISO 27001, SOC 2 o equivalentes.
- Definir la ubicación geográfica de los datos (importante para el RGPD).
- Gestionar las claves de cifrado de forma independiente del proveedor (BYOK - Bring Your Own Key).
- Establecer acuerdos de nivel de servicio (SLA) que garanticen la disponibilidad y recuperación.

## 6. Continuidad de Negocio

### 6.1 Marco y relación con ISO 22301

La continuidad de negocio dentro del SGSI está regulada por el Control 5.30 del Anexo A de la ISO 27001:2022 (Preparación para las TIC para la continuidad del negocio). Para una gestión completa, se complementa con la norma ISO 22301, estándar internacional específico para los Sistemas de Gestión de la Continuidad de Negocio (SGCN/BCMS).

El objetivo es garantizar que los procesos de negocio críticos puedan continuar o recuperarse rápidamente ante incidentes graves: desastres naturales, ciberataques, fallos de infraestructura, pandemias o cualquier interrupción significativa.

### 6.2 Conceptos clave

| Concepto                   | Siglas | Definición                                                                                |
|----------------------------|--------|-------------------------------------------------------------------------------------------|
| Recovery Time Objective    | RTO    | Tiempo máximo tolerable de interrupción. ¿Cuánto tiempo puede estar inactivo el servicio? |
| Recovery Point Objective   | RPO    | Máxima pérdida de datos tolerable. ¿Cuántos datos podemos permitirnos perder?             |
| Business Impact Analysis   | BIA    | Análisis que identifica procesos críticos y cuantifica el impacto de su interrupción.     |
| Business Continuity Plan   | BCP    | Plan para mantener la operación del negocio durante y tras una interrupción.              |
| Disaster Recovery Plan     | DRP    | Plan técnico para recuperar los sistemas de TI tras un desastre.                          |
| Maximum Tolerable Downtime | MTD    | Tiempo máximo que una organización puede sobrevivir sin un proceso crítico.               |

### 6.3 Análisis de Impacto en el Negocio (BIA)

El BIA es el fundamento de la continuidad de negocio. Su objetivo es identificar y priorizar los procesos críticos de la organización y cuantificar el impacto financiero, operacional y reputacional de su interrupción.

El proceso de BIA incluye los siguientes pasos:

- Identificación de procesos de negocio: Inventariar todos los procesos y sus dependencias (sistemas, personas, proveedores).
- Evaluación del impacto: Para cada proceso, cuantificar el impacto de la interrupción en función del tiempo (1 hora, 4 horas, 1 día, 1 semana).
- Determinación del RTO y RPO: Definir objetivos de recuperación basados en el impacto y las necesidades del negocio.
- Identificación de recursos críticos: Sistemas, aplicaciones, datos, personal e instalaciones necesarios para cada proceso crítico.
- Análisis de dependencias externas: Proveedores, servicios en la nube, telecomunicaciones.

## 6.4 Plan de Continuidad de Negocio (BCP)

El BCP documenta cómo la organización continuará operando durante y después de una interrupción. Debe incluir:

- Alcance y objetivos: Qué procesos cubre el plan y qué objetivos de recuperación persigue.
- Estructura de gestión de crisis: Roles, responsabilidades y cadena de mando durante una crisis. Incluir datos de contacto de emergencia.
- Procedimientos de activación: Criterios y proceso para declarar una situación de continuidad.
- Estrategias de continuidad: Alternativas operativas para cada proceso crítico (trabajo remoto, instalaciones alternativas, proveedores de respaldo).
- Procedimientos de comunicación: Cómo y cuándo comunicar a empleados, clientes, proveedores y autoridades.
- Procedimientos de regreso a la normalidad: Pasos para volver a la operación normal una vez superado el incidente.

## 6.5 Plan de Recuperación ante Desastres (DRP)

El DRP es el componente técnico del BCP, centrado en la recuperación de los sistemas e infraestructuras de TI. Incluye:

- Inventario de sistemas críticos: Servidores, aplicaciones, bases de datos y sus interdependencias.
- Procedimientos de recuperación: Pasos detallados para restaurar cada sistema, en orden de prioridad según el BIA.
- Infraestructura alternativa: Centros de datos de respaldo (Hot Site, Warm Site, Cold Site).
- Procedimientos de failover: Cambio automático o manual a sistemas de respaldo.
- Gestión de datos: Procedimientos de restauración de copias de seguridad y verificación de integridad.

| Tipo de sitio | Descripción                                                                               | RTO típico    | Coste    |
|---------------|-------------------------------------------------------------------------------------------|---------------|----------|
| Hot Site      | Centro de datos completamente equipado y operativo en tiempo real (replicación continua). | Minutos       | Muy alto |
| Warm Site     | Centro preparado con equipamiento básico. Requiere configuración antes de activarse.      | Horas         | Medio    |
| Cold Site     | Espacio físico disponible pero sin equipamiento. Requiere instalación completa.           | Días          | Bajo     |
| Cloud DR      | Uso de infraestructura cloud bajo demanda para recuperación.                              | Horas-Minutos | Variable |

## 6.6 Pruebas y mantenimiento

Un BCP/DRP no verificado no tiene valor real. La norma exige pruebas periódicas:

- Revisión documental: Verificar que los documentos están actualizados y son precisos.
- Prueba de escritorio (Tabletop Exercise): Simulación en sala sin impacto operativo. El equipo de crisis discute los escenarios y las respuestas.
- Simulacro parcial: Probar componentes específicos del plan (ej. restauración de copias de seguridad).
- Simulacro completo: Activación completa del BCP/DRP en un entorno controlado.
- Post-mortem: Tras cada prueba o incidente real, documentar lecciones aprendidas y mejorar el plan.

## 7. Proceso de Certificación ISO 27001

### 7.1 Pasos para la certificación

El proceso de certificación ISO 27001 sigue una secuencia bien definida:

- Fase 1 - Análisis GAP: Evaluar el estado actual frente a los requisitos de la norma para identificar brechas.
- Fase 2 - Implantación del SGSI: Establecer políticas, procedimientos, controles y documentación requerida.
- Fase 3 - Auditoría interna: Verificar que el SGSI funciona conforme a los requisitos antes de la auditoría externa.
- Fase 4 - Revisión por la dirección: La alta dirección revisa el SGSI y su desempeño.
- Fase 5 - Auditoría de certificación (Etapa 1): Revisión documental por el organismo certificador.
- Fase 6 - Auditoría de certificación (Etapa 2): Auditoría in situ. Verificación de la implementación real.
- Fase 7 - Certificación: Emisión del certificado (válido 3 años con auditorías de seguimiento anuales).

### 7.2 Documentación obligatoria

La ISO 27001 exige mantener la siguiente documentación como evidencia del SGSI:

- Política del SGSI y políticas de seguridad específicas.
- Alcance del SGSI (cláusula 4.3).
- Evaluación y tratamiento de riesgos (cláusulas 6.1.2 y 6.1.3).
- Declaración de Aplicabilidad (SoA).
- Plan de Tratamiento de Riesgos (PTR).
- Objetivos de seguridad de la información (cláusula 6.2).
- Resultados de auditorías internas y revisiones por la dirección.
- No conformidades y acciones correctivas (cláusula 10.1).

## 8. Anexo A — Controles de Referencia (ISO 27001:2022)

La versión 2022 del Anexo A contiene 93 controles organizados en 4 categorías (en la versión 2013 eran 114 controles en 14 dominios). Se añadieron 11 controles nuevos, se fusionaron otros y se reordenaron.

### 8.1 Controles Organizativos (37 controles — 5.1 a 5.37)

Abarcan la gobernanza de la seguridad de la información: políticas, roles, gestión de activos, relaciones con proveedores, gestión de incidentes y continuidad.

- 5.1 Políticas de seguridad de la información.
- 5.3 Segregación de funciones.
- 5.7 Inteligencia de amenazas (NUEVO en 2022).
- 5.15 a 5.18 Control de acceso a la información.
- 5.23 Seguridad de la información para el uso de servicios en la nube (NUEVO en 2022).
- 5.30 Preparación de las TIC para la continuidad del negocio.
- 5.36 Cumplimiento de políticas, normas y estándares de seguridad de la información.

### 8.2 Controles de Personas (8 controles — 6.1 a 6.8)

Regulan la seguridad en relación con los recursos humanos: selección, formación, concienciación, teletrabajo y disciplina.

- 6.1 Investigación de antecedentes (screening).
- 6.3 Concienciación, educación y formación en seguridad de la información.
- 6.7 Teletrabajo (NUEVO en 2022).
- 6.8 Notificación de eventos de seguridad de la información.

### 8.3 Controles Físicos (14 controles — 7.1 a 7.14)

Protegen los activos físicos: instalaciones, equipos, medios y áreas seguras.

- 7.1 Perímetros de seguridad física.
- 7.4 Monitorización de la seguridad física (NUEVO en 2022).
- 7.8 Ubicación y protección de los equipos.
- 7.10 Medios de almacenamiento.
- 7.14 Eliminación segura o reutilización del equipo.

### 8.4 Controles Tecnológicos (34 controles — 8.1 a 8.34)

Son los controles más numerosos e incluyen seguridad de endpoints, redes, aplicaciones, criptografía, gestión de vulnerabilidades y monitorización.

- 8.2 Derechos de acceso privilegiado.



- 8.5 Autenticación segura.
- 8.7 Protección contra malware.
- 8.8 Gestión de vulnerabilidades técnicas.
- 8.9 Gestión de la configuración (NUEVO en 2022).
- 8.10 Eliminación de información (NUEVO en 2022).
- 8.11 Enmascaramiento de datos (NUEVO en 2022).
- 8.12 Prevención de fuga de datos — DLP (NUEVO en 2022).
- 8.13 Copia de seguridad de la información.
- 8.15 Registro de actividades (logging).
- 8.16 Actividades de monitorización (NUEVO en 2022).
- 8.20 Seguridad de redes.
- 8.24 Uso de criptografía.
- 8.25 a 8.31 Seguridad en el ciclo de vida del desarrollo seguro.
- 8.34 Protección de los sistemas de información durante las pruebas de auditoría.

## 9. Referencias y Recursos

Para profundizar en los contenidos de este documento, se recomiendan las siguientes fuentes:

- ISO/IEC 27001:2022 — Norma oficial (disponible en [iso.org](https://www.iso.org)).
- ISO/IEC 27002:2022 — Guía de implementación de los controles del Anexo A.
- ISO/IEC 27005:2022 — Gestión de riesgos de seguridad de la información.
- ISO 22301:2019 — Sistemas de gestión de la continuidad de negocio.
- INCIBE ([incibe.es](https://www.incibe.es)) — Guías gratuitas del SGSI para empresas españolas.
- CCN-CERT ([ccn-cert.cni.es](https://ccn-cert.cni.es)) — Guías del Centro Criptológico Nacional (ENS).
- ISMS Forum Spain ([ismsforum.es](https://ismsforum.es)) — Recursos y comunidad profesional.
- NIST Cybersecurity Framework ([nist.gov](https://nist.gov)) — Marco complementario de ciberseguridad.

Este documento ha sido elaborado como material de referencia para un Proyecto Fin de Carrera. Los contenidos reflejan los requisitos y recomendaciones de la norma ISO/IEC 27001:2022 y su ecosistema normativo asociado.